

Assessment Standards

Both penetration tests and vulnerability assessments should comply with specific standards to be accredited and accepted by governments and legal authorities. Such standards help ensure that the assessment is carried out thoroughly in a generally agreed-upon manner to increase the efficiency of these assessments and reduce the likelihood of an attack on the organization.

Compliance Standards

Each regulatory compliance body has its own information security standards that organizations must adhere to maintain their accreditation. The big compliance players in information security are [PCI](#), [HIPAA](#), [FISMA](#), and [ISO 27001](#).

These accreditations are necessary because it certifies that an organization has had a third-party vendor evaluate its environment. Organizations also rely on these accreditations for business operations since some companies won't do business without specific accreditations from organizations.

Payment Card Industry Data Security Standard (PCI DSS)

The [Payment Card Industry Data Security Standard \(PCI DSS\)](#) is a commonly known standard in information security that implements requirements for organizations that handle credit cards. While not a government regulation, organizations that store, process, or transmit cardholder data must still implement PCI DSS guidelines. This would include banks or online stores that handle their own payment solutions (e.g., Amazon).

PCI DSS requirements include internal and external scanning of assets. For example, any credit card data that is being processed or transmitted must be done in a Cardholder Data Environment (CDE). The CDE environment must be adequately segmented from normal assets. CDE environments are segmented off from an organization's regular environment to protect any cardholder data from being compromised during an attack and limit internal access to data.



[Source](#)

Health Insurance Portability and Accountability Act (HIPAA)

[HIPAA](#) is the [Health Insurance Portability and Accountability Act](#), which is used to protect patients' data. HIPAA does not necessarily

require vulnerability scans or assessments; however, a risk assessment and vulnerability identification are required to maintain HIPAA accreditation.

Federal Information Security Management Act (FISMA)

The [Federal Information Security Management Act \(FISMA\)](#) is a set of standards and guidelines used to safeguard government operations and information. The act requires an organization to provide documentation and proof of a vulnerability management program to maintain information technology systems' proper availability, confidentiality, and integrity.

ISO 27001

[ISO 27001](#) is a standard used worldwide to manage information security. [ISO 27001](#) requires organizations to perform quarterly external and internal scans.

Although compliance is essential, it should not drive a vulnerability management program. Vulnerability management should consider the uniqueness of an environment and the associated risk appetite to an organization.

The [International Organization for Standardization \(ISO\)](#) maintains technical standards for pretty much anything you can imagine. The [ISO 27001](#) standard deals with information security. ISO 27001 compliance depends upon maintaining an effective Information Security Management System. To ensure compliance, organizations must perform penetration tests in a carefully designed way.

Penetration Testing Standards

Penetration tests should not be performed without any [rules](#) or [guidelines](#). There must always be a specifically defined scope for a pentest, and the owner of a network must have a [signed legal contract](#) with pentesters outlining what they're allowed to do and what they're not allowed to do. Pentesting should also be conducted in such a way that minimal harm is done to a company's computers and networks. Penetration testers should avoid making changes wherever possible (such as changing an account password) and limit the amount of data removed from a client's network. For example, instead of removing sensitive documents from a file share, a screenshot of the folder names should suffice to prove the risk.

In addition to scope and legalities, there are also various pentesting standards, depending on what kind of computer system is being assessed. Here are some of the more common standards you may use as a pentester.

PTES

The [Penetration Testing Execution Standard \(PTES\)](#) can be applied to all types of penetration tests. It outlines the phases of a penetration test and how they should be conducted. These are the sections in the PTES:

- Pre-engagement Interactions
- Intelligence Gathering
- Threat Modeling
- Vulnerability Analysis
- Exploitation
- Post Exploitation
- Reporting

OSSTMM

[OSSTMM](#) is the [Open Source Security Testing Methodology Manual](#), another set of guidelines pentesters can use to ensure they're doing their jobs properly. It can be used alongside other pentest standards.

OSSTMM is divided into five different channels for five different areas of pentesting:

1. Human Security (human beings are subject to social engineering exploits)
2. Physical Security
3. Wireless Communications (including but not limited to technologies like WiFi and Bluetooth)
4. Telecommunications
5. Data Networks

NIST

The **NIST** (**National Institute of Standards and Technology**) is well known for their **NIST Cybersecurity Framework**, a system for designing incident response policies and procedures. NIST also has a Penetration Testing Framework. The phases of the NIST framework include:

- Planning
- Discovery
- Attack
- Reporting

OWASP

OWASP stands for the **Open Web Application Security Project**. They're typically the go-to organization for defining testing standards and classifying risks to web applications.

OWASP maintains a few different standards and helpful guides for assessment various technologies:

- [Web Security Testing Guide \(WSTG\)](#)
- [Mobile Security Testing Guide \(MSTG\)](#)
- [Firmware Security Testing Methodology](#)

[← Previous](#)[Next →](#)[✔ Mark Complete & Next](#)

Table of Contents

Security Assessments

[Security Assessments](#)[Vulnerability Assessment](#)[Assessment Standards](#)

Vulnerability Scoring and Reporting

[Common Vulnerability Scoring System \(CVSS\)](#)[Common Vulnerabilities and Exposures \(CVE\)](#)

Nessus

[Vulnerability Scanning Overview](#)[Getting Started with Nessus](#)[Nessus Scan](#)[Advanced Settings](#)[Working with Nessus Scan Output](#)

Scanning Issues

 Nessus Skills Assessment

OpenVAS

Getting Started with OpenVAS

OpenVAS Scan

Exporting The Results

 OpenVAS Skills Assessment

Reporting

Reporting

My Workstation

O F F L I N E

 Start Instance

 / 1 spawns left